# Industrial Test Bench - Caso di Studio

# 0. Panoramica

Questo documento di studio fornisce un'analisi critica della piattaforma di test industriale, coprendone lo *stato attuale* (AS-IS), lo *stato target desiderato* (TO-BE), e la trasformazione architettonica necessaria per introdurre automazione, capacità di supervisione remota e controlli di sicurezza informatica in conformità agli standard IEC 62443, mantenendo l'indipendenza della sicurezza funzionale.

## 0.1. Capitolo 01 - Descrizione del Test Bench AS-IS

Il capitolo descrive l'architettura attuale del test bench basata su PLC locali con coordinamento manuale per i sottosistemi di pressione e temperatura. Attualmente non esiste connettività remota. Le responsabilità operative ricadono completamente sull'operatore che coordina manualmente la sincronizzazione tra i sottosistemi, estrae i dati e assembla i rapporti. I dati provengono da più fonti indipendenti senza correlazione automatica.

Contenuti principali:

- Architettura di controllo basata su PLC locale
- Flusso operativo manuale
- Gestione e reportistica dei dati
- Caratteristiche di sicurezza attuali (basate su consapevolezza dell'operatore)
- Modello di responsabilità AS-IS

## 0.2. Capitolo 02 - Addendum Tecnico AS-IS

Questo capitolo fornisce una descrizione tecnica dettagliata dei componenti hardware, dell'architettura di controllo e dei flussi di dati attuali. Include un inventario completo dell'hardware (PLC, HMI, sottosistema pressione con pompa e valvole, sottosistema temperatura con controller standalone, datalogger industriale e Device Under Test dotato di API non utilizzata). Il capitolo evidenzia anche i gap di integrazione e le limitazioni della configurazione attuale.

Contenuti principali:

- Inventario e specifiche tecniche dei componenti
- Sottosistema pressione (sensori, valvole, controllo)
- Sottosistema temperatura (controller indipendente)
- Apparecchiature di acquisizione dati
- Caratteristiche del DUT (Device Under Test)
- Flussi di dati durante e dopo il test
- Gap di integrazione identificati

## 0.3. Capitolo 03 - Descrizione Interfacce e Flussi di Dati AS-IS

Il capitolo fornisce una mappatura dettagliata di tutte le interfacce fisiche e logiche del sistema, inclusi i flussi di controllo, misurazioni e acquisizione dati. Include tabelle esaustive delle interfacce di controllo (da HMI a PLC, comandi verso pompe e valvole, feedback di pressione e temperatura), interfacce di acquisizione dati (dal sensore al datalogger) e interfacce di esportazione dati (SD/USB verso operatore). Identifica anche l'API del DUT (attualmente non utilizzata) come capabilità presente ma non integrata nel flusso operativo.

Contenuti principali:

- Mappa delle interfacce fisiche e logiche
- Interfacce di controllo e sicurezza
- Interfacce di acquisizione dati
- Interfacce di esportazione file
- Interfaccia API del DUT (non utilizzata)
- Flussi di dati end-to-end
- Punti di correlazione e gap
- Touchpoint dell'operatore

## 0.4. Capitolo 04 - Descrizione del Test Bench TO-BE

Il capitolo descrive l'architettura target che trasforma il sistema da un ambiente coordinato manualmente a una piattaforma integrata, automatizzata e parzialmente supervisionata a distanza. Il TO-BE introduce orchestrazione centralizzata del processo, infrastruttura di dati unificata, capacità di supervisione remota tramite HMI su PC e tablet, e separazione rigorosa tra logica di controllo del processo e funzioni di sicurezza. Il modello di responsabilità si evolve con il sistema che diventa orchestratore del processo e l'operatore supervisore.

Contenuti principali:

- Architettura di controllo centralizzata
- Infrastruttura di dati integrata
- Capacità di supervisione remota
- Architettura di sicurezza funzionale nel TO-BE
- Fondamenti di sicurezza informatica (IEC 62443)
- Modello di responsabilità TO-BE
- Caratteristiche chiave dello stato target

## 0.5. Capitolo 05 - Analisi dell'Evoluzione delle Responsabilità AS-IS vs TO-BE

Questo capitolo analizza la redistribuzione delle responsabilità nella transizione da AS-IS a TO-BE. In AS-IS l'operatore è l'orchestratore del processo (coordinamento manuale, verifica dei parametri, monitoraggio continuo, estrazione e aggregazione dei dati). Nel TO-BE il sistema diventa l'orchestratore (sequenze sincronizzate, validazione della configurazione, monitoraggio continuo automatico, raccolta e aggregazione dei dati) mentre l'operatore diventa l'autorità decisionale e supervisoria (autorizzazione all'avvio, supervisione del processo, convalida dei risultati). Il capitolo fornisce una tabella sintetica della ridistribuzione responsabilità tra Umano, Sistema e Logica di Sicurezza.

Contenuti principali:

- Cambio strutturale nel modello di responsabilità
- Coordinamento del processo: operatore → sistema
- Validazione parametri: operatore → sistema + operatore
- Monitoraggio: attivo → supervisorio
- Gestione dati: manuale → automatizzato
- Generazione rapporti: artigianale → generato automaticamente
- Nuova definizione del ruolo dell'operatore
- Implicazioni della trasformazione

## 0.6. Capitolo 06 - Sfide Emergenti di Sicurezza Informatica e Interazione con la Sicurezza Funzionale

Il capitolo analizza come l'introduzione di connettività e automazione crea nuove superfici di esposizione ai rischi informatici che possono influenzare direttamente o indirettamente la sicurezza funzionale. Stabilisce il principio critico che la sicurezza funzionale non deve dipendere dall'integrità informatica, il che significa che la logica di sicurezza deve essere indipendente dai livelli supervisivi e dal controllo remoto non può bypassare i blocchi di sicurezza. Il capitolo descrive scenari di rischio combinato (manipolazione della ricetta, soppressione degli allarmi, controllo remoto non autorizzato) e le strategie di mitigazione.

Contenuti principali:

- Cambio nella natura del rischio (da errore umano a vulnerabilità sistemica)
- Nuove superfici di esposizione informatica
- Modello di interazione Sicurezza e Cyber Security
- Principio critico di progettazione (la sicurezza non dipende dal cyber)
- Scenari di rischio combinato
- Implicazioni di governance
- Considerazioni di validazione e test

## 0.7. Capitolo 07 - Analisi dei GAP AS-IS vs TO-BE

Il capitolo fornisce un'analisi strutturata dei gap tra la configurazione attuale (AS-IS) e l'architettura desiderata (TO-BE) attraverso cinque aree di intervento: A) Orchestrazione del Processo, B) Gestione dei Dati e Tracciabilità, C) Sicurezza Funzionale, D) Sicurezza Informatica (OT), E) Governance e Gestione del Ciclo di Vita. Per ogni area sono definiti gli obiettivi macro, gli standard di riferimento, i passi di implementazione macro e i dettagli tecnici micro. L'analisi fornisce una roadmap strutturata per l'evoluzione architettonica del sistema.

Contenuti principali:

- Aree di intervento (5 aree principali)
- Obiettivi macro per ogni area
- Standard di riferimento (IEC 61508, ISO 13849, IEC 62443, IEC 61511, ISA-95, ALCOA+)
- Passi di implementazione macro
- Dettagli tecnici micro
- Sommario del gap
- Principi di trasformazione

## 0.8. Capitolo 08 - Analisi Formale dei GAP secondo IEC 62443

Il capitolo fornisce un'analisi formale secondo IEC 62443 della configurazione attuale rispetto ai requisiti di sicurezza informatica. Definisce lo scope del sistema, identifica zone e condotti, determina il Security Level Target (SL-T = 2, basato su esposizione industriale moderata e implicazioni di sicurezza), valuta il Security Level Attuale (SL-A ≈ 0-1). Analizza il gap per ognuno dei 7 Foundational Requirements di IEC 62443-3-3 (FR1-FR7), valuta la maturità della sicurezza a livello componente e del programma, e conclude che l'architettura AS-IS è fisicamente sicura ma cyber immaturi e richiede interventi significativi in segmentazione, autenticazione, integrità, logging e governance.

Contenuti principali:

- Scopo e metodologia dell'analisi IEC 62443
- Definizione del sistema e modello di zone
- Determinazione del Security Level Target

- Valutazione dei 7 Foundational Requirements
- Gap analysis per ogni requisito (FR1-FR7)
- Valutazione della sicurezza a livello componente
- Valutazione del programma di sicurezza
- Conclusioni esecutive e raccomandazioni

# 1. Descrizione del Test Bench AS-IS

## 1.1. 1. Panoramica

Il sistema attuale consiste in più test bench industriali utilizzati per la verifica di componenti meccanici in condizioni critiche di pressione e temperatura. L'architettura di controllo è principalmente basata su sistemi PLC locali senza connettività remota.

Le operazioni sono prevalentemente manuali e coordinate direttamente dagli operatori.

## 1.2. 2. Architettura di Controllo

### 1.2.1. 2.1 Controllo Locale Basato su PLC

- Ogni sottosistema (pressione, temperatura, acquisizione dati) è controllato localmente.
- I PLC eseguono logica sequenziale di base.
- I controllori possono operare come unità autonome.
- Non esiste una logica di orchestrazione centralizzata.

### 1.2.2. 2.2 Mancanza di Accesso Remoto

- Nessuna supervisione remota via PC o tablet.
- Nessuna connettività esterna a reti aziendali o esterne.
    - Il sistema è effettivamente isolato dall'infrastruttura IT.

## 1.3. 3. Flusso Operativo

### 1.3.1. 3.1 Esecuzione del Test

Gli operatori sono responsabili di:

- Avviare manualmente ogni sottosistema.
- Sincronizzare le fasi di pressione, temperatura e acquisizione.
- Monitorare l'evoluzione del test.
- Identificare condizioni anomale.
- Decidere quando interrompere il test.

Il coordinamento è guidato dall'operatore piuttosto che dal sistema.

### 1.3.2. 3.2 Attività Post-Test

Alla fine di ogni test:

- I dati vengono estratti manualmente dai singoli strumenti.
- I file vengono raccolti separatamente.
- I dati vengono aggregati manualmente.

Non esiste una correlazione automatica tra ID del test, ID del componente e dati di misurazione.

## 1.4. 4. Gestione dei Dati e Reportistica

- I dati vengono elaborati manualmente.
- I report vengono creati utilizzando fogli di calcolo (ad es. Excel).
- La copia-incolla e i calcoli manuali sono comuni.
- La tracciabilità dipende dalla disciplina dell'operatore.
    - Non esiste un repository centralizzato o un database strutturato.

## 1.5. 5. Caratteristiche di Sicurezza (Stato Attuale)

- La sicurezza si basa principalmente su:
    - Consapevolezza dell'operatore
    - Protezioni hardware di base
    - Blocchi locali (se presenti)
- Nessuna orchestrazione centralizzata della sicurezza.
- Nessuna validazione automatica globale degli stati del processo.

La sicurezza dipende fortemente dalla supervisione umana.

## 1.6. 6. Esposizione alla Sicurezza Informatica (Stato Attuale)

- Superficie di attacco minima dovuta all'isolamento del sistema.
- Nessun accesso remoto.
- Nessuna connettività di rete esterna.
- Nessuna infrastruttura digitale centralizzata da compromettere.

Il rischio informatico è attualmente basso perché la connettività è assente.

## 1.7. 7. Modello di Responsabilità (AS-IS)

### 1.7.1. Responsabilità dell'Operatore

- Coordinamento del sistema
- Verifica dei parametri
- Sincronizzazione manuale
- Rilevamento di anomalie
- Estrazione dei dati
- Creazione di report
- Convalida finale

L'operatore agisce come orchestratore primario del processo.

### 1.7.2. Responsabilità del Sistema

- Eseguire la logica di controllo locale
- Applicare i setpoint configurati manualmente
- Generare dati di misurazione grezzi
- Attivare protezioni locali di base

Il sistema esegue ma non governa il processo complessivo.

## 1.8. 8. Osservazioni Chiave

- Elevata dipendenza dall'esperienza umana.
- Riprenibilità limitata.
- Gestione manuale dei dati.
- Bassa esposizione informatica.
- Sicurezza principalmente procedurale piuttosto che sistemica.

# 2. Addendum Tecnico AS-IS

## 2.1. Descrizione Dettagliata dell'Architettura Tecnica

## 2.2. 1. Scopo di questo Addendum

Questo documento fornisce una descrizione tecnica più approfondita dell'architettura attuale (AS-IS) del test bench.

Completa la descrizione principale del sistema AS-IS fornendo dettagli su:

- Componenti hardware
- Interfacce di controllo
- Flussi di dati
- Capacità del Device Under Test (DUT)
- Limitazioni di integrazione attuali

## 2.3. 2. Inventario degli Asset

### 2.3.1. 2.1 Strato di Controllo

#### PLC

- Modello: Siemens S7-1200 (es. CPU 1214C)
- I/O:
    - Ingressi Digitali (DI)
    - Uscite Digitali (DO)
    - Ingressi Analogici (AI 4-20 mA)
    - Uscite Analogiche (AO 4-20 mA)
- Ruolo:
    - Controllo sequenze di base (avvio, mantenimento, arresto, depressurizzazione)
    - Comando attuatori
    - Gestione allarmi di base

#### HMI

- Modello: Siemens KTP700 Basic
- Connesso localmente al PLC
- Funzionalità:
    - Inserimento manuale setpoint

    - Parametri ricetta di base
    - Visualizzazione stato
    - Nessuna memorizzazione dati centralizzata

### 2.3.2. 2.2 Sottosistema Pressione

- Pompa alta pressione (azionamento elettrico)
- Valvola di scarico a solenoide (controllo DO)
- Valvola proporzionale opzionale (AO 4-20 mA)
- Trasduttore di pressione:
    - Range: 0-400 bar
    - Uscita: 4-20 mA
    - Lettura tramite canale AI del PLC
- Pressostato meccanico:
    - Cablaggio diretto alla catena di sicurezza

### 2.3.3. 2.3 Sottosistema Temperatura

- Camera climatica o sistema di riscaldamento
- Controllore di temperatura stand-alone (es. Eurotherm / Omron)
- Sensori di temperatura (PT100 / termocoppie)
- Controllore opera in modo indipendente
- Interazione con PLC limitata a:
    - Segnali digitali RUN / READY / FAULT
    - Nessuna gestione coordinata dei profili

### 2.3.4. 2.4 Apparecchiature di Acquisizione Dati

- Datalogger industriale stand-alone
- Registra segnali di pressione e temperatura
- Supporto di memorizzazione:
    - Scheda SD
    - Memoria USB
- Formato dati:
    - Esportazione CSV
- Nessuna integrazione real-time con PLC o HMI

## 2.4. 3. Architettura di Sicurezza (Implementazione Attuale)

- Catena di relè di sicurezza (logica cablata)
    - Ingressi includono:
        - Arresto di emergenza

        - Interlock porta
        - Pressostato meccanico
    - Uscite:
        - Rimozione potenza dalla pompa
        - Rimozione potenza dal sistema di riscaldamento
- Nessun PLC di sicurezza
- Nessuna logica di sicurezza software-based
- Il reset di sicurezza richiede interazione manuale locale

La sicurezza opera indipendentemente dalla logica PLC.

## 2.5. 4. Caratteristiche del Device Under Test (DUT)

Il DUT frequentemente include elettronica embedded con intelligenza interna.

### 2.5.1. 4.1 Capacità Funzionali del DUT

- Misurazioni da sensori interni (es. pressione, temperatura, posizione, corrente)
- Capacità di logging onboard
- Registrazione eventi
- Memoria interna di archiviazione

### 2.5.2. 4.2 Metodi di Esportazione Dati del DUT

Al termine del ciclo di test:

- Rimozione scheda SD ed estrazione file
- Download file via Ethernet (procedura manuale)
- Dati forniti come log strutturati (es. CSV, formato proprietario)

### 2.5.3. 4.3 API del DUT (Non Utilizzata Attualmente)

Il DUT fornisce un'interfaccia programmabile (non integrata nel flusso di lavoro attuale):

- API REST o protocollo TCP-based
- Accesso alle misure in tempo reale o near real-time
- Endpoint per interrogazioni di stato
- Capacità di streaming dei log durante l'esecuzione del test

Stato attuale:

- L'API esiste ma non è integrata nel processo del test bench
- Nessun software sviluppato per consumare dati live dal DUT
- Il DUT è trattato operativamente come una black box fino all'estrazione dei log

## 2.6. 5. Flussi di Dati Attuali

### 2.6.1. 5.1 Durante il Test

- Il PLC controlla il sottosistema pressione
- Il controllore di temperatura esegue il proprio profilo
- Il datalogger registra i segnali
- Il DUT registra dati interni in modo indipendente

Non esiste un identificatore di test condiviso propagato automaticamente tra i sistemi.

La sincronizzazione dipende dalle azioni dell'operatore.

### 2.6.2. 5.2 Fine del Test

L'operatore esegue:

- Estrazione dati dal datalogger (USB / SD)
- Estrazione log dal DUT (SD o download Ethernet)
- Associazione manuale di:
    - Numero seriale DUT
    - Parametri di test
    - File del datalogger
    - Dati profilo temperatura

L'aggregazione dei dati è manuale e tipicamente eseguita utilizzando fogli di calcolo.

## 2.7. 6. Gap di Integrazione Identificati

- Nessuna logica di orchestrazione centralizzata
- Nessun ID test unificato tra i sottosistemi
- Nessuna correlazione automatica di dati multi-sorgente
- Capacità API del DUT non utilizzata
- Nessun repository dati strutturato
- Nessuna architettura di rete tra gli asset

## 2.8. 7. Caratteristiche della Linea di Base Architettonica

- Forte isolamento fisico di sicurezza
- Connettività digitale minima
- Alta dipendenza dall'operatore
- Molteplici sorgenti dati indipendenti
- Nessuna segmentazione di rete OT richiesta (rete assente)

Questa configurazione AS-IS fornisce bassa esposizione cyber ma alto carico manuale operativo e ripetibilità limitata.

# 3. Descrizione Interfacce e Flussi di Dati AS-IS

## 3.1. 1. Scopo

Questo documento mappa le **interfacce** e i **flussi di dati** dell'architettura attuale (AS-IS) del test bench industriale, includendo:

- Interfacce di controllo (segnali e percorsi di comando)
- Percorsi di misurazione
- Percorsi di logging/esportazione dati
- Interfacce dati del Device Under Test (DUT) (compresa l'API attualmente non utilizzata)

L'obiettivo è fornire una baseline concreta per derivare i requisiti architetturali TO-BE.

## 3.2. 2. Confini del Sistema (AS-IS)

Asset inclusi:

- PLC (controllo locale)
- HMI locale
- Sottosistema pressione (pompa, valvole, trasduttore di pressione, pressostato meccanico)
- Sottosistema temperatura (controllore stand-alone + camera/riscaldatore)
- Datalogger stand-alone
- DUT con intelligenza onboard e logging
- Azioni dell'operatore (coordinamento manuale ed estrazione dati)

Escluso (AS-IS):

- Accesso remoto (supervisione PC/tablet)
- Server centrale / historian / database
- Pipeline di generazione report automatizzata
- Segmentazione rete OT (nessuna rete OT in pratica)

## 3.3. 3. Mappa delle Interfacce (Fisiche / Logiche)

### 3.3.1. 3.1 Interfacce di Controllo e Sicurezza (Segnali)

| ID Interfaccia | Da | A | Tipo | Segnale/Protocollo | Scopo | Note |
|---|---|---|---|---|---|---|
| IF-01 | HMI | PLC | Fieldbus | Profinet (HMI runtime) | Inserimento comandi operatore, | Solo locale |

| ID Interfaccia | Da | A | Tipo | Segnale/Protocollo | Scopo setpoint | Note |
|---|---|---|---|---|---|---|
| IF-02 | PLC | Pompa | Digitale | DO (24V) | Avvio/Arresto pompa | Via contattore /relè |
| IF-03 | PLC | Valvola di scarico | Digitale | DO (24V) | Apertura/Chiusura controllata depressurizzazione | La catena di sicurezza può sovrascrivere via rimozione potenza |
| IF-04 | PLC | Valvola proporzionale (opzionale) | Analogico | AO 4-20 mA | Comando regolazione pressione | Solo se installato |
| IF-05 | Trasduttore pressione | PLC | Analogico | AI 4-20 mA | Misurazione pressione | PLC usa per controllo di processo/ allarmi |
| IF-06 | Pressostato meccanico | Catena relè sicurezza | Digitale | Contatto pulito | Rilevamento sovrappressione indipendente | Cablaggio diretto |
| IF-07 | E-Stop | Catena relè sicurezza | Digitale | Contatto pulito | Arresto emergenza | Cablaggio diretto |
| IF-08 | Interlock porta | Catena relè sicurezza | Digitale | Contatto pulito | Sicurezza protezioni | Cablaggio diretto |
| IF-09 | Catena relè sicurezza | Alimentazione pompa/riscaldatore | Potenza | Controllo contattore sicurezza | Rimozione energia ad attuatori pericolosi | Indipendente da PLC |
| IF-10 | Controllore temp | Camera/Riscaldatore | Locale | I/O vendor | Attuazione temperatura | Interno al sottosistema temp |
| IF-11 | PLC | Controllore temp | Digitale | DI/DO contatto pulito | Stato RUN/READY /FAULT e abilitazione semplice | Nessun coordinamento profili |
| IF-12 | Sensori | Controllore | Analogico | PT100/TC | Misurazione temperatura | Non acquisito |

| ID Interfaccia | Da temp | A temp | Tipo | Segnale/Protocollo | Scopo | Note da PLC in AS-IS |
|---|---|---|---|---|---|---|

### 3.3.2. 3.2 Interfacce di Acquisizione Dati (Da Misura a Logger)

| ID Interfaccia | Da | A | Tipo | Segnale/Protocollo | Dati | Note |
|---|---|---|---|---|---|---|
| IF-20 | Trasduttore pressione (o mirror PLC) | Datalogger | Analogico | 4-20 mA / 0-10V | Trend pressione | Cablaggio logger varia per banco |
| IF-21 | Controllore temp (uscita analogica) o sonda dedicata | Datalogger | Analogico | 4-20 mA / Modulo PT100/TC | Trend temperatura | Spesso canali separati |
| IF-22 | Sensori ausiliari (se presenti) | Datalogger | Misto | Analogico/Digitale | Segnali opzionali | Non standardizzato |

### 3.3.3. 3.3 Interfacce di Esportazione Dati (File)

| ID Interfaccia | Da | A | Supporto | Formato | Tempistica | Note |
|---|---|---|---|---|---|---|
| IF-30 | Datalogger | Operatore | SD / USB | CSV | Fine test | Estrazione manuale |
| IF-31 | HMI (valori) | Operatore | Manuale | Note / foto / copia manuale | Qualsiasi momento | Spesso non strutturato |
| IF-32 | Controllore temp | Operatore | USB / esportazione locale | CSV / proprietario | Fine test o per batch | Dipendente dal vendor |
| IF-33 | DUT | Operatore | Scheda SD | File log (CSV/proprietario) | Fine test (dopo finalizzazione log) | Rimozione manuale |
| IF-34 | DUT | Operatore | Ethernet (diretto) | Trasferimento file (SMB/FTP/HTTP download) | Fine test (dopo finalizzazione log) | Usato occasionalmente |
| IF-35 | Operatore | Template Report | PC (offline) | Workbook Excel | Post-test | Aggregazione manuale |

### 3.3.4. 3.4 Interfaccia Dati Real-Time del DUT (Presente ma NON utilizzata)

| ID Interfaccia | Da | A | Protocollo | Capacità | Stato in AS-IS | Rischio/Nota |
|---|---|---|---|---|---|---|
| IF-40 | DUT | Client esterno | REST/HTTP o TCP | Lettura misure live, stato, stream eventi | Non usata | Richiede software client + integrazione rete |
| IF-41 | Client esterno | DUT | REST/HTTP o TCP | Avvio/arresto logging, recupero log parziali | Non usata | Deve essere vincolato per evitare controllo non intenzionale |

## 3.4. 4. Mappa dei Flussi di Dati (End-to-End)

### 3.4.1. 4.1 Flussi di Dati Durante il Test

DF-01 Controllo di processo (pressione)

- L'operatore inserisce i parametri su HMI → il PLC esegue la sequenza base
- Il PLC comanda pompa/valvole
- Il feedback di pressione è letto dal PLC per la regolazione del processo e gli allarmi

DF-02 Evoluzione temperatura

- Il controllore di temperatura esegue il profilo configurato localmente
- Il PLC può ricevere stati grossolani READY/FAULT (se cablato)
- I dati di temperatura non sono nativamente centralizzati

DF-03 Trending e registrazione

- Il datalogger registra i canali di pressione e temperatura
- Il DUT registra i propri sensori interni in modo indipendente
- Non esiste un identificatore di test condiviso tra le sorgenti

### 3.4.2. 4.2 Flussi di Dati a Fine Test

DF-10 Esportazione logger

- L'operatore estrae il CSV dal logger via SD/USB
- I file sono denominati manualmente o inseriti in cartelle (denominazione non standard)

DF-11 Esportazione DUT

- L'operatore finalizza il log sul DUT
- Dati estratti via rimozione SD o download file Ethernet
- Tipicamente eseguito solo dopo il completamento completo del test

DF-12 Esportazione controllore temperatura (opzionale)

- L'operatore esporta un file di profilo o trend, a volte in formato vendor

DF-13 Assemblaggio report

- L'operatore correla manualmente:
    - Seriale/batch DUT

    - Parametri di test (note HMI/ricetta)
    - CSV logger (pressione/temp)
    - File log DUT
    - Esportazione controllore (opzionale)
- Il report è costruito in Excel (copia/incolla, calcoli, grafici)

## 3.5. 5. Punti di Correlazione e Gap

### 3.5.1. 5.1 Punti di Correlazione

- Tempo di inizio test (definito dall'operatore)
- Durata test / tempo di mantenimento
- Forma della rampa di pressione
- Milestone del profilo di temperatura
- Timestamp interni del DUT (se presenti)

### 3.5.2. 5.2 Gap Attuali

- Nessun ID Test automatico propagato tra i sottosistemi
- Nessuna sincronizzazione temporale garantita tra:
    - Orologio del datalogger
    - Orologio interno del DUT
    - Timestamp PLC/HMI (se presenti)
- La denominazione manuale dei file è un singolo punto di fallimento per la tracciabilità
- I dati sono multi-sorgente e post-correlati manualmente
- La capacità API del DUT è inutilizzata, impedendo l'integrazione near-real-time

## 3.6. 6. Punti di Contatto dell'Operatore

- Sequenziamento avvio/arresto su più dispositivi
- Conferma manuale degli stati di prontezza
- Esportazione manuale da logger/controllore/DUT
- Associazione manuale dei file a un test
- Calcoli manuali e compilazione report

Questi punti di contatto sono le principali fonti di variabilità operativa e errori nel modello AS-IS.

## 3.7. 7. Diagramma Riassuntivo (Testuale)

- Percorso di Controllo

    - HMI → PLC → (Pompa / Valvole)
    - Catena Relè Sicurezza → (Rimozione potenza a Pompa/Riscaldatore) [override indipendente]
    - Controllore Temp → (Camera/Riscaldatore) [indipendente]
- Percorso di Misurazione
    - Trasduttore Pressione → PLC (feedback processo)
    - Segnali Pressione/Temp → Datalogger (registrazione)
    - Sensori interni DUT → Log interno DUT (registrazione)
- Percorso di Esportazione
    - Datalogger → SD/USB → Operatore
    - Controllore Temp → USB/export → Operatore (opzionale)
    - DUT → Download SD/Ethernet → Operatore
    - Operatore → Excel → Report
- Capacità Non Utilizzata
    - API DUT (dati live) esiste ma non fa parte del flusso operativo

## 3.8. 8. Driver di Baseline per TO-BE

- Introdurre un ID Test univoco e propagarlo tra le sorgenti dati
- Ridurre i passaggi di esportazione manuale attraverso percorsi di ingestione strutturati
- Migliorare correlazione e tracciabilità (timestamp, metadati, azioni operatore)
- Decidere se e come utilizzare le API real-time del DUT preservando l'indipendenza di sicurezza
- Preservare l'indipendenza della sicurezza dai livelli supervisivi/dati

# 4. Descrizione del Test Bench TO-BE

## 4.1. 1. Panoramica

Il sistema target evolve da un ambiente di test coordinato manualmente a una piattaforma di test industriale integrata, automatizzata e parzialmente supervisionata da remoto.

L'obiettivo è aumentare la ripetibilità, ridurre l'intervento manuale, centralizzare la gestione dei dati e introdurre una supervisione remota controllata mantenendo o migliorando la sicurezza funzionale.

## 4.2. 2. Architettura di Controllo Target

### 4.2.1. 2.1 Orchestrazione Centralizzata del Processo

- Una logica di controllo centrale coordina tutti i sottosistemi (pressione, temperatura, acquisizione).
- Il sequenziamento automatizzato gestisce:
    - Profili di rampa
    - Sincronizzazione tra sottosistemi
    - Fasi di mantenimento
    - Procedure di spegnimento controllato
- La validazione pre-test dei parametri e dello stato del sistema viene eseguita automaticamente.

### 4.2.2. 2.2 Infrastruttura di Dati Integrata

- Tutti i sottosistemi trasmettono i dati a un repository centralizzato.
- Ogni test è identificato univocamente e associato a:
    - ID Componente
    - Ricetta di test
    - Timestamp
    - ID Operatore
- La correlazione dei dati è automatica e strutturata.

### 4.2.3. 2.3 Capacità di Supervisione Remota

- HMI basato su PC per il controllo supervisivo.
- Monitoraggio basato su tablet (funzionalità ristretta).
- Accesso remoto controllato per la manutenzione (tramite gateway sicuro).

I privilegi di controllo remoto sono limitati e basati sui ruoli.

## 4.3. 3. Flusso Operativo

### 4.3.1. 3.1 Preparazione del Test

Responsabilità dell'operatore:

- Selezionare la ricetta di test.
- Confermare la corretta configurazione del componente.
- Autorizzare l'avvio del test.

Responsabilità del sistema:

- Validare la configurazione.
- Verificare interlock e condizioni di sicurezza.
- Verificare disponibilità e plausibilità dei sensori.

L'avvio del test è condizionato al successo della validazione.

### 4.3.2. 3.2 Esecuzione Automatizzata del Test

Responsabilità del sistema:

- Coordinare tutti i sottosistemi.
- Garantire temporizzazione e sincronizzazione.
- Monitorare le variabili di processo.
- Registrare tutti i dati rilevanti in tempo reale.
- Attivare allarmi o sequenze di arresto quando necessario.

Responsabilità dell'operatore:

- Supervisionare l'evoluzione del processo.
- Rispondere agli allarmi.
- Intervenire se necessario.

L'operatore passa da esecutore a supervisore.

### 4.3.3. 3.3 Fine Test e Reportistica

Responsabilità del sistema:

- Finalizzare automaticamente la sequenza di test.
- Memorizzare tutti i dati correlati.
- Generare report di test standardizzato.
- Registrare interventi dell'operatore e anomalie.

Responsabilità dell'operatore:

- Rivedere il report generato.
- Validare o rifiutare l'esito del test.
- Fornire l'approvazione finale.

## 4.4. 4. Architettura di Sicurezza (Stato Target)

- Funzioni di sicurezza implementate in logica di sicurezza dedicata.
- Le funzioni critiche includono:
    - Protezione da sovrappressione
    - Trip da sovratemperatura
    - Depressurizzazione sicura
    - Gestione interlock protezioni
- Il reset di sicurezza richiede conferma fisica locale.
- I sistemi remoti non possono sovrascrivere gli interlock di sicurezza.

La sicurezza funzionale rimane indipendente dai sistemi supervisivi.

## 4.5. 5. Fondamenti di Sicurezza Informatica

L'introduzione della connettività crea una nuova superficie di esposizione.

I principi di sicurezza includono:

- Segmentazione di rete tra domini OT e IT.
- Controllo accessi basato sui ruoli.
- Autenticazione per azioni critiche.
- Logging e tracciabilità delle modifiche di configurazione.
- Manutenzione remota sicura tramite gateway controllato.

I controlli cyber proteggono l'integrità del processo ma non sostituiscono le funzioni di sicurezza.

## 4.6. 6. Modello di Responsabilità (TO-BE)

### 4.6.1. Responsabilità dell'Operatore

- Autorizzare l'esecuzione del test.
- Supervisionare il processo automatizzato.
- Gestire eventi anomali.
- Validare i risultati finali.
- Mantenere la responsabilità per l'accettazione del test.

### 4.6.2. Responsabilità del Sistema

- Coordinare l'intero ciclo di vita del test.
- Validare le precondizioni.
- Eseguire sequenze deterministiche.
- Aggregare e memorizzare i dati.
- Generare report formali.

- Mantenere la tracciabilità degli eventi.

### 4.6.3. Responsabilità della Logica di Sicurezza

- Far rispettare i limiti operativi sicuri.
- Sovrascrivere comandi non sicuri.
- Forzare lo stato sicuro in condizioni pericolose.
- Richiedere reset locale dopo trip di sicurezza.

## 4.7. 7. Caratteristiche Chiave dello Stato Target

- Ridotta sincronizzazione manuale.
- Maggiore ripetibilità.
- Ciclo di vita dei dati strutturato.
- Supervisione remota controllata.
- Chiara separazione tra controllo di processo e logica di sicurezza.
- Emergenza della sicurezza informatica come requisito a livello di sistema.

# 5. Analisi dell'Evoluzione delle Responsabilità AS-IS vs TO-BE

## 5.1. Focus sull'Evoluzione delle Responsabilità dell'Operatore

## 5.2. 1. Introduzione

Questo documento analizza la transizione dal sistema di test attuale (AS-IS) coordinato manualmente alla futura piattaforma (TO-BE) automatizzata e supervisionata da remoto.

Particolare attenzione è dedicata all'evoluzione delle responsabilità dell'Operatore e alla ridistribuzione della responsabilità tra Umano, Sistema e Logica di Sicurezza.

## 5.3. 2. Trasformazione Strutturale della Responsabilità

La trasformazione non è puramente tecnologica. Rappresenta una ridistribuzione fondamentale della responsabilità operativa.

Nel modello AS-IS: L'Operatore è l'orchestratore del processo.

Nel modello TO-BE: Il Sistema diventa l'orchestratore del processo, mentre l'Operatore diventa supervisore e autorità decisionale.

## 5.4. 3. Mappatura della Responsabilità

### 5.4.1. 3.1 Coordinamento del Processo

AS-IS:

- L'operatore avvia manualmente i sottosistemi
- L'operatore sincronizza pressione, temperatura e acquisizione
- Il coordinamento esiste cognitivamente

TO-BE:

- Il sistema esegue sequenze sincronizzate
- L'operatore autorizza l'avvio ma non gestisce i tempi
- Il coordinamento è algoritmico e deterministico

Impatto: La responsabilità si sposta dalla memoria e abilità umana a una logica di controllo validata e testabile.

### 5.4.2. 3.2 Validazione dei Parametri

AS-IS:

- L'operatore verifica i setpoint
- Rischio di omissione o configurazione errata

TO-BE:

- Il sistema valida automaticamente la configurazione
- Gli interlock prevengono condizioni non sicure o inconsistenti
- L'operatore conferma ma non calcola

Impatto: Riduzione degli errori umani legati alla configurazione.

### 5.4.3. 3.3 Monitoraggio Durante il Test

AS-IS:

- L'operatore monitora continuamente tutti gli strumenti
- Il rilevamento delle anomalie dipende dalla vigilanza

TO-BE:

- Il sistema monitora continuamente le variabili di processo
- Allarmi automatici e rilevamento soglie
- L'operatore supervisiona gli allarmi piuttosto che i segnali grezzi

Impatto: Passaggio dal controllo manuale attivo al controllo supervisorio.

### 5.4.4. 3.4 Gestione dei Dati

AS-IS:

- Estrazione dati manuale
- Aggregazione manuale
- Costruzione report manuale

TO-BE:

- Raccolta dati automatica
- Archiviazione strutturata
- Generazione report automatizzata
- L'operatore valida l'output finale

Impatto: La responsabilità si sposta dall'elaborazione dati alla validazione dei risultati.

### 5.4.5. 3.5 Supervisione della Sicurezza

AS-IS:

- Sicurezza principalmente procedurale e guidata dall'operatore
- Possono esistere protezioni locali ma il coordinamento globale è umano

TO-BE:

- Funzioni di sicurezza implementate in logica indipendente
- Trip automatico e applicazione dello stato sicuro

- L'operatore non può sovrascrivere da remoto le funzioni di sicurezza critiche

Impatto: L'autorità di sicurezza si sposta dalla reazione dell'operatore all'applicazione deterministica della sicurezza.

## 5.5. 4. Tabella Sintetica della Ridistribuzione della Responsabilità

| Attività | AS-IS | TO-BE | Trasferimento Responsabilità |
|---|---|---|---|
| Coordinamento sottosistemi | Operatore | Sistema | Umano → Algoritmo |
| Validazione parametri | Operatore | Sistema + Operatore | Umano → Assistito da sistema |
| Monitoraggio processo | Operatore | Sistema + Operatore | Attivo → Supervisorio |
| Aggregazione dati | Operatore | Sistema | Manuale → Automatizzato |
| Generazione report | Operatore | Sistema | Artigianale → Generato |
| Validazione finale | Operatore | Operatore | Invariato |
| Applicazione trip sicurezza | Operatore Locale + | Sistema Sicurezza | Umano → Logica Deterministica |

## 5.6. 5. Nuova Definizione del Ruolo dell'Operatore

Nello scenario TO-BE, l'Operatore diventa:

- Autorità di autorizzazione prima dell'avvio del test
- Autorità supervisoria durante l'esecuzione
- Autorità decisionale per l'accettazione del test
- Entità responsabile per l'approvazione finale

L'Operatore non è più il sincronizzatore del processo, ma rimane il decisore umano responsabile.

## 5.7. 6. Implicazioni Emergenti

La ridistribuzione della responsabilità introduce nuovi requisiti:

- La logica di sistema deve essere verificabile e validata
- La logica di sicurezza deve essere dimostrabilmente indipendente
- I controlli di sicurezza informatica devono proteggere i percorsi decisionali automatizzati
- L'interazione uomo-macchina deve prevenire usi impropri non sicuri

La trasformazione riduce la variabilità operativa, ma aumenta la dipendenza dall'integrità del sistema.

## 5.8. 7. Principio Fondamentale della Trasformazione

AS-IS: L'intelligenza umana garantisce il coordinamento.

TO-BE: L'intelligenza del sistema garantisce il coordinamento, l'intelligenza umana garantisce il giudizio.

Questa transizione definisce le fondamenta sia per la validazione della sicurezza funzionale che per i requisiti dell'architettura di sicurezza informatica.

# 6. Sfide Emergenti di Sicurezza Informatica e Interazione con la Sicurezza Funzionale

## 6.1. Interpretazione in Relazione alla Sicurezza Funzionale

## 6.2. 1. Introduzione

La transizione da un sistema isolato e coordinato manualmente a una piattaforma automatizzata e parzialmente connessa introduce un cambiamento fondamentale nell'esposizione al rischio.

Mentre l'automazione aumenta la ripetibilità e riduce la variabilità operativa umana, la connettività introduce rischi cyber sistemici che possono influenzare direttamente o indirettamente la sicurezza funzionale.

Questo documento analizza le problematiche emergenti di sicurezza informatica e la loro interazione con i requisiti di sicurezza.

## 6.3. 2. Cambio nella Natura del Rischio

### 6.3.1. Modello di Rischio AS-IS

- Rischio dominato dall'errore umano
- Esposizione cyber minima dovuta all'isolamento
- Sicurezza principalmente procedurale e applicata localmente

### 6.3.2. Modello di Rischio TO-BE

- Variabilità manuale ridotta
- Maggiore dipendenza dall'integrità della logica di controllo
- Introduzione di connettività di rete e accesso remoto
- Emergere di minacce digitali malevole o accidentali

Il rischio si sposta dall'errore umano individuale alla vulnerabilità sistemica.

## 6.4. 3. Nuove Superfici di Esposizione Cyber

L'introduzione di supervisione e capacità remote crea nuovi vettori di attacco:

### 6.4.1. 3.1 Sistemi Supervisori (HMI / SCADA)

Rischi potenziali:

- Modifica non autorizzata delle ricette di test
- Manipolazione dei parametri di processo
- Soppressione o alterazione degli allarmi
- Visualizzazione falsa delle variabili di processo

Rilevanza per la sicurezza: Informazioni supervisorie errate possono ritardare l'intervento umano o portare a decisioni inappropriate.

### 6.4.2. 3.2 Canali di Accesso Remoto

Rischi potenziali:

- Accesso non autorizzato ai sistemi di controllo
- Movimento laterale dalla rete IT alla rete OT
- Modifiche di configurazione non controllate

Rilevanza per la sicurezza: L'accesso remoto potrebbe abilitare comandi non sicuri se non tecnicamente vincolato.

### 6.4.3. 3.3 Infrastruttura di Dati Centralizzata

Rischi potenziali:

- Compromissione dell'integrità dei dati
- Perdita di tracciabilità
- Manomissione dei record di test

Rilevanza per la sicurezza: Risultati di test corrotti possono validare componenti non sicuri o invalidare componenti conformi.

## 6.5. 4. Modello di Interazione tra Sicurezza Funzionale e Sicurezza Informatica

La Sicurezza Funzionale garantisce:

- Applicazione dello stato sicuro
- Comportamento di trip deterministico
- Protezione contro guasti prevedibili

La Sicurezza Informatica garantisce:

- Integrità dei comandi
- Autenticità degli utenti
- Riservatezza dei dati sensibili
- Disponibilità dei sistemi

L'intersezione si verifica dove una compromissione digitale potrebbe influenzare comportamenti rilevanti per la sicurezza.

## 6.6. 5. Principio Critico di Progettazione

La sicurezza non deve dipendere dall'integrità cyber.

Questo significa:

- La logica di sicurezza deve essere indipendente dai livelli supervisivi
- I sistemi remoti non possono sovrascrivere gli interlock di sicurezza
- Il reset di sicurezza richiede interazione fisica locale
- Le soglie critiche sono applicate nella logica di sicurezza dedicata

I controlli cyber proteggono il processo, ma la logica di sicurezza protegge le persone e le attrezzature.

## 6.7. 6. Scenari di Rischio Combinato Emergenti

### 6.7.1. Scenario A: Manipolazione della Ricetta

Se un attaccante modifica un profilo di rampa di pressione, il processo può superare i limiti meccanici sicuri.

Mitigazione:

- Validazione dei parametri all'interno della logica di controllo
- Soglie di sicurezza rigide indipendenti dalla ricetta

### 6.7.2. Scenario B: Soppressione degli Allarmi

Se gli allarmi sono nascosti o disabilitati nell'HMI, la reazione dell'operatore può essere ritardata.

Mitigazione:

- Trip di sicurezza indipendente dalla visibilità HMI
- Ridondanza degli allarmi o segnalazione hardware

### 6.7.3. Scenario C: Controllo Remoto Non Autorizzato

Se l'accesso remoto viene sfruttato, potrebbero essere emessi comandi non sicuri.

Mitigazione:

- Controllo degli accessi basato sui ruoli
- Autenticazione multi-fattore
- Logging dei comandi e tracciabilità delle sessioni
- Segmentazione della rete

## 6.8. 7. Implicazioni di Governance

Il sistema TO-BE richiede:

- Chiara separazione tra domini IT e OT
- Proprietà definita delle responsabilità di sicurezza informatica
- Gestione della configurazione documentata

- Procedure di controllo delle modifiche
- Validazione degli aggiornamenti software
- Valutazioni di sicurezza periodiche

La validazione della sicurezza funzionale deve considerare i pericoli indotti dal cyber come parte dell'analisi dei rischi a livello di sistema.

## 6.9. 8. Considerazioni di Validazione e Test

I test di Sicurezza Informatica dovrebbero includere:

- Test di robustezza dell'autenticazione
- Verifica della segmentazione di rete
- Validazione del controllo accessi basato sui ruoli
- Controlli di logging e tracciabilità

I test di Sicurezza Funzionale dovrebbero confermare:

- Indipendenza del trip di sicurezza dal livello supervisivo
- Applicazione dello stato sicuro in caso di comportamento digitale anomalo
- Risposta appropriata in caso di tentativi di comandi corrotti

Gli scenari di test combinati devono verificare che una compromissione cyber non possa disabilitare le funzioni di sicurezza.

## 6.10. 9. Conclusione Strategica

L'evoluzione verso l'automazione e la connettività trasforma il sistema da: Controllo di sicurezza centrato sull'umano a Controllo deterministico centrato sul sistema.

Questa transizione richiede:

- Separazione architettonica esplicita
- Strategia cyber defense-in-depth
- Indipendenza di sicurezza verificata
- Valutazione del rischio integrata che copra entrambi i domini

La Sicurezza Informatica protegge l'integrità del sistema. La Sicurezza Funzionale protegge la vita umana e le risorse fisiche.

Entrambe devono coesistere senza compromettere l'una l'altra.

# 7. Analisi dei GAP AS-IS vs TO-BE

## 7.1. 1. Scopo

Questo documento definisce l'analisi strutturata dei GAP tra la configurazione attuale AS-IS e l'architettura desiderata TO-BE del sistema di test bench industriale.

L'obiettivo è:

- Identificare le aree di intervento
- Definire gli obiettivi macro
- Delineare i passi di implementazione macro
- Scomporre in micro-passi tecnici
- Riferire gli standard di Sicurezza e Sicurezza Informatica applicabili

Questo documento serve come baseline decisionale e di pianificazione architettonica.

## 7.2. 2. Aree di Intervento e Obiettivi Macro

### 7.2.1. AREA A - Orchestrazione del Processo

#### Obiettivi Macro

A1 – Transizione dal coordinamento manuale all'orchestrazione centralizzata deterministica A2 – Introdurre ID Test unificato e sincronizzazione temporale

#### Standard di Riferimento

- IEC 61508 (principi di capacità sistematica)
- ISA-95 (integrazione enterprise-control)
- ISO 9001 / ISO 17025 (tracciabilità)

### 7.2.2. AREA B - Gestione dei Dati & Tracciabilità

#### Obiettivi Macro

B1 – Unificare la raccolta dati multi-sorgente B2 – Garantire integrità e correlazione dei dati B3 – Automatizzare la generazione di report strutturati

#### Standard di Riferimento

- ISO 17025 (integrità dei dati)
- ISO 9001 (controllo documenti)
- IEC 62443-3-3 (controlli integrità dati)
- Principi ALCOA+

### 7.2.3. AREA C - Sicurezza Funzionale

#### Obiettivi Macro

C1 – Definire il confine architetturale tra logica di processo e logica di sicurezza C2 – Garantire l'indipendenza della sicurezza dai sistemi supervisivi C3 – Estendere l'analisi dei pericoli per includere guasti indotti dal cyber

#### Standard di Riferimento

- IEC 61508
- ISO 13849 / IEC 62061
- ISO 12100
- IEC 61511 (se ambiente di processo)

### 7.2.4. AREA D - Sicurezza Informatica (OT)

#### Obiettivi Macro

D1 – Introdurre architettura di rete OT segmentata D2 – Proteggere autenticità e integrità dei comandi D3 – Controllare l'accesso remoto D4 – Integrare in sicurezza l'API del DUT

#### Standard di Riferimento

- Famiglia IEC 62443
- NIST SP 800-82
- ISO 27001

### 7.2.5. AREA E - Governance & Gestione del Ciclo di Vita

#### Obiettivi Macro

E1 – Introdurre gestione della configurazione e versioning E2 – Formalizzare la gestione delle modifiche E3 – Integrare il ciclo di vita di validazione combinato Safety e Cyber

#### Standard di Riferimento

- Modello di ciclo di vita IEC 61508
- IEC 62443-2-1
- ISO 9001

## 7.3. 3. Passi di Implementazione Macro

### 7.3.1. AREA A – Orchestrazione

1. Definire l'architettura di controllo centralizzata
2. Introdurre il concetto di ID Test
3. Definire il modello temporale unificato
4. Ridefinire le responsabilità operatore vs sistema

### 7.3.2. AREA B – Dati

1. Definire il modello dati comune
2. Introdurre il repository centralizzato
3. Definire la pipeline di ingestione
4. Definire la struttura di reportistica automatizzata

### 7.3.3. AREA C – Sicurezza

1. Aggiornare l'analisi dei pericoli e dei rischi
2. Definire l'architettura dei confini di sicurezza
3. Validare l'indipendenza della sicurezza
4. Definire la strategia di proof-test e validazione

### 7.3.4. AREA D – Cyber

1. Definire zone e condotti (IEC 62443)
2. Implementare la segmentazione di rete
3. Definire il modello di autenticazione basato sui ruoli
4. Hardening di PLC/HMI/IPC
5. Implementare logging e monitoraggio di sicurezza

### 7.3.5. AREA E – Governance

1. Definire il processo di gestione della configurazione
2. Introdurre il controllo versione
3. Definire le procedure di aggiornamento sicuro
4. Implementare il registro di tracciabilità delle modifiche

## 7.4. 4. Micro-Passi Tecnici

### 7.4.1. AREA A – Dettagli Tecnici

- Implementare logica di orchestrazione centralizzata (PLC o IPC)
- Implementare sincronizzazione temporale basata su NTP
- Generare ID Test univoco (UUID) per esecuzione
- Propagare l'ID Test a tutti i sottosistemi
- Introdurre interlock automatici tra sottosistemi

### 7.4.2. AREA B – Dettagli Tecnici

- Definire lo schema di database strutturato (SQL/Time-series)
- Implementare parser automatico per CSV del logger

- Integrare client API DUT per dati real-time (se adottato)
- Automatizzare la generazione report e firma digitale
- Implementare policy di backup e retention

### 7.4.3. AREA C – Dettagli Tecnici

- Mantenere indipendenza fisica della sicurezza
- Assicurare che i sistemi remoti non possano modificare le soglie di sicurezza
- Validare comportamento fail-safe in caso di perdita rete o crash IPC
- Eseguire scenari di test combinati cyber-safety

### 7.4.4. AREA D – Dettagli Tecnici

- Creare segmento di rete OT dedicato
- Introdurre firewall tra IT e OT
- Disabilitare servizi non utilizzati su PLC/IPC
- Implementare RBAC e MFA
- Introdurre application whitelisting
- Centralizzare il logging degli eventi di sicurezza

### 7.4.5. AREA E – Dettagli Tecnici

- Introdurre repository Git interno per software di controllo
- Backup dei programmi PLC con versioning
- Definire processo formale di richiesta modifiche
- Implementare test di regressione prima del rilascio

## 7.5. 5. Concetto di Sintesi del GAP

La trasformazione da AS-IS a TO-BE rappresenta:

- Passaggio dal coordinamento centrato sull'umano all'orchestrazione centrata sul sistema
- Transizione dalla sicurezza hardware isolata all'architettura di sicurezza validata
- Introduzione del rischio cyber che richiede mitigazione strutturata
- Evoluzione dalla gestione manuale dei dati al ciclo di vita digitale strutturato

Questa analisi GAP fornisce la roadmap strutturata per la progettazione architettonica e l'evoluzione controllata del sistema.

# 8. Analisi Formale dei GAP secondo IEC 62443

## 8.1. 1. Scopo del Documento

Questo documento fornisce un'analisi formale dei GAP dell'architettura attuale AS-IS del test bench industriale rispetto ai requisiti dello standard IEC 62443.

L'obiettivo è:

- Definire lo scope del sistema valutato
- Identificare zone e condotti
- Determinare il Security Level Target (SL-T)
- Valutare l'Actual Security Level (SL-A)
- Identificare i gap rispetto ai Foundational Requirements IEC 62443-3-3
- Evidenziare i controlli programmatici mancanti (IEC 62443-2-1)
- Identificare i gap a livello di componente (IEC 62443-4-2)

Questo report è strutturato in allineamento con la metodologia di assessment IEC 62443.

## 8.2. 2. Spiegazione dei Termini Chiave di IEC 62443

Per chiarezza, le seguenti abbreviazioni e concetti sono utilizzati in questo documento secondo la terminologia IEC 62443.

### 8.2.1. 2.1 Livelli di Sicurezza (Security Levels)

SL (Security Level)

Un livello definito di resistenza contro un profilo di minaccia definito. La norma IEC 62443 definisce quattro Security Levels (SL 1-4), ciascuno corrispondente a un profilo di attaccante con crescenti capacità, motivazione e risorse.

SL-T (Target Security Level)

Il Security Level richiesto per il sistema, determinato attraverso un risk assessment formale secondo IEC 62443-3-2. L'SL-T rappresenta il livello di protezione necessario basato sull'analisi delle minacce, delle vulnerabilità e dell'impatto potenziale.

SL-A (Achieved or Actual Security Level)

Il Security Level attualmente raggiunto dal sistema nella sua configurazione AS-IS. L'SL-A rappresenta il livello effettivo di protezione implementato, misurato rispetto ai Foundational Requirements.

SL-C (Capability Security Level)

Il Security Level che i componenti del sistema sono in grado di raggiungere quando adeguatamente configurati e integrati. L'SL-C rappresenta la capacità intrinseca dei componenti, indipendentemente dalla loro configurazione attuale.

### 8.2.2. 2.2 Foundational Requirements (FR)

FR (Foundational Requirement)

Una delle sette categorie di requisiti di sicurezza di alto livello definite in IEC 62443-3-3. Ogni FR rappresenta un obiettivo di sicurezza fondamentale che deve essere soddisfatto per raggiungere un determinato Security Level.

Le sette categorie FR sono:

- **FR1** – Identification and Authentication Control (IAC)
- **FR2** – Use Control (UC)
- **FR3** – System Integrity (SI)
- **FR4** – Data Confidentiality (DC)
- **FR5** – Restricted Data Flow (RDF)
- **FR6** – Timely Response to Events (TRE)
- **FR7** – Resource Availability (RA)

## 8.2.3. 2.3 Zone e Conduits (IEC 62443-3-2)

La norma IEC 62443-3-2 introduce il modello **Zone & Conduits** come approccio fondamentale per la segmentazione e il controllo dei flussi di comunicazione nei sistemi di automazione e controllo industriale (IACS).

### 2.3.1 Definizione di Zona

**Zona (Zone)**

Secondo IEC 62443-3-2, una **zona** è definita come:

*"Un raggruppamento di asset logici o fisici che condividono requisiti di sicurezza comuni"*

Caratteristiche di una zona:

- **Omogeneità dei requisiti**: tutti gli asset in una zona hanno lo stesso Security Level Target
- **Perimetro definito**: confini chiari che separano la zona da altre zone e dall'esterno
- **Controllo degli accessi**: tutti i flussi di comunicazione in ingresso/uscita sono controllati
- **Policy di sicurezza comune**: regole uniformi applicate a tutti gli elementi della zona

Principi di definizione delle zone:

- Funzionalità comune (es. controllo, supervisione, dati)
- Livello di criticità equivalente
- Requisiti di disponibilità, integrità e confidenzialità simili
- Appartenenza allo stesso dominio operativo (OT) o informativo (IT)

### 2.3.2 Definizione di Conduit

**Conduit (Condotto)**

Secondo IEC 62443-3-2, un **conduit** è definito come:

*"Un canale di comunicazione logico tra due o più zone che è monitorato e controllato"*

Caratteristiche di un conduit:

- **Controllo esplicito**: ogni conduit implementa policy di sicurezza specifiche
- **Monitoraggio**: il traffico sul conduit è ispezionato e registrato
- **Autenticazione**: verifica dell'identità delle entità comunicanti
- **Autorizzazione**: controllo delle operazioni permesse attraverso il conduit
- **Integrità**: protezione contro manipolazione dei dati in transito
- **Confidenzialità**: protezione dei dati sensibili tramite cifratura (dove richiesto)

Tipi di conduit comuni:

- **Firewall industriale**: filtraggio stateful o deep packet inspection

- **Data diode**: comunicazione unidirezionale fisica
- **VPN/Tunnel cifrato**: protezione dei dati su reti non trusted
- **Gateway protocollo**: traduzione e controllo tra protocolli diversi

### 2.3.3 Principi di Segmentazione secondo la Norma

La norma IEC 62443-3-2 stabilisce i seguenti principi guida per la segmentazione:

**1. Defense in Depth**

Implementare controlli multipli e stratificati. La compromissione di un singolo controllo non deve compromettere l'intero sistema.

**2. Least Privilege**

Ogni zona e ogni conduit deve garantire solo il minimo accesso necessario per le funzioni operative legittime.

**3. Separation of Concerns**

Separare funzionalmente e logicamente:

- Domini OT (Operational Technology) da domini IT (Information Technology)
- Funzioni di controllo da funzioni di supervisione
- Sistemi critici da sistemi non critici
- Entità trusted da entità non trusted

**4. Explicit Deny (Default Deny)**

Tutto ciò che non è esplicitamente permesso deve essere vietato. La politica predefinita è il rifiuto dell'accesso.

**5. Monitoraggio e Visibilità**

Ogni flusso di comunicazione tra zone deve essere monitorabile e tracciabile per supportare detection e response.

**6. Scalabilità e Manutenibilità**

Il modello deve essere documentato, comprensibile e gestibile nel ciclo di vita del sistema.

### 2.3.4 Benefici del Modello Zone & Conduits

- **Riduzione della superficie d'attacco**: limitazione dei punti di ingresso
- **Contenimento**: limitazione della propagazione laterale in caso di compromissione
- **Tracciabilità**: visibilità sui flussi di comunicazione critici
- **Compliance**: facilita la dimostrazione di conformità ai requisiti normativi
- **Resilienza**: isolamento dei guasti e degli attacchi in zone specifiche

## 8.3. 3. Definizione del Sistema (IEC 62443-3-2)

### 8.3.1. 3.1 Asset Identificati (AS-IS)

- PLC (Siemens S7-1200)
- HMI locale
- Controllore di temperatura (stand-alone)
- Datalogger stand-alone
- DUT (Device Under Test) con capacità API Ethernet
- Catena relè di sicurezza (non rilevante dal punto di vista cyber ma critica per la sicurezza)
- Postazione operatore (creazione report offline)

Non esiste un'architettura di rete OT formalmente definita nella configurazione AS-IS.

## 8.3.2. 3.2 Modello Preliminare di Zone (Concettuale)

Il seguente modello identifica le zone concettuali del sistema, che costituiranno la base per il modello formale Zone & Conduits descritto in dettaglio nella sezione FR5.

### Zona Z1 – Zona di Controllo Base

- PLC (Siemens S7-1200)
- HMI locale
- Controllore di temperatura
- Datalogger

### Zona Z2 – Zona DUT

- Dispositivo DUT
- Interfaccia Ethernet

### Zona Z3 – Zona Supervisiva (TO-BE)

- IPC / SCADA
- Repository dati centrale

### Zona Z4 – Zona IT Enterprise

- PC per reportistica
- Rete aziendale

### Stato attuale dei condotti

I condotti in AS-IS sono principalmente fisici/manuali (USB, SD, cavo Ethernet diretto). Nessun condotto logico o segmentazione di rete sono formalmente definiti.

**Nota:** Il modello formale completo con definizione dettagliata delle zone, dei conduits (C1-C4), delle regole di flusso e dei requisiti di sicurezza è presentato nella sezione **FR5 – Restricted Data Flow**.

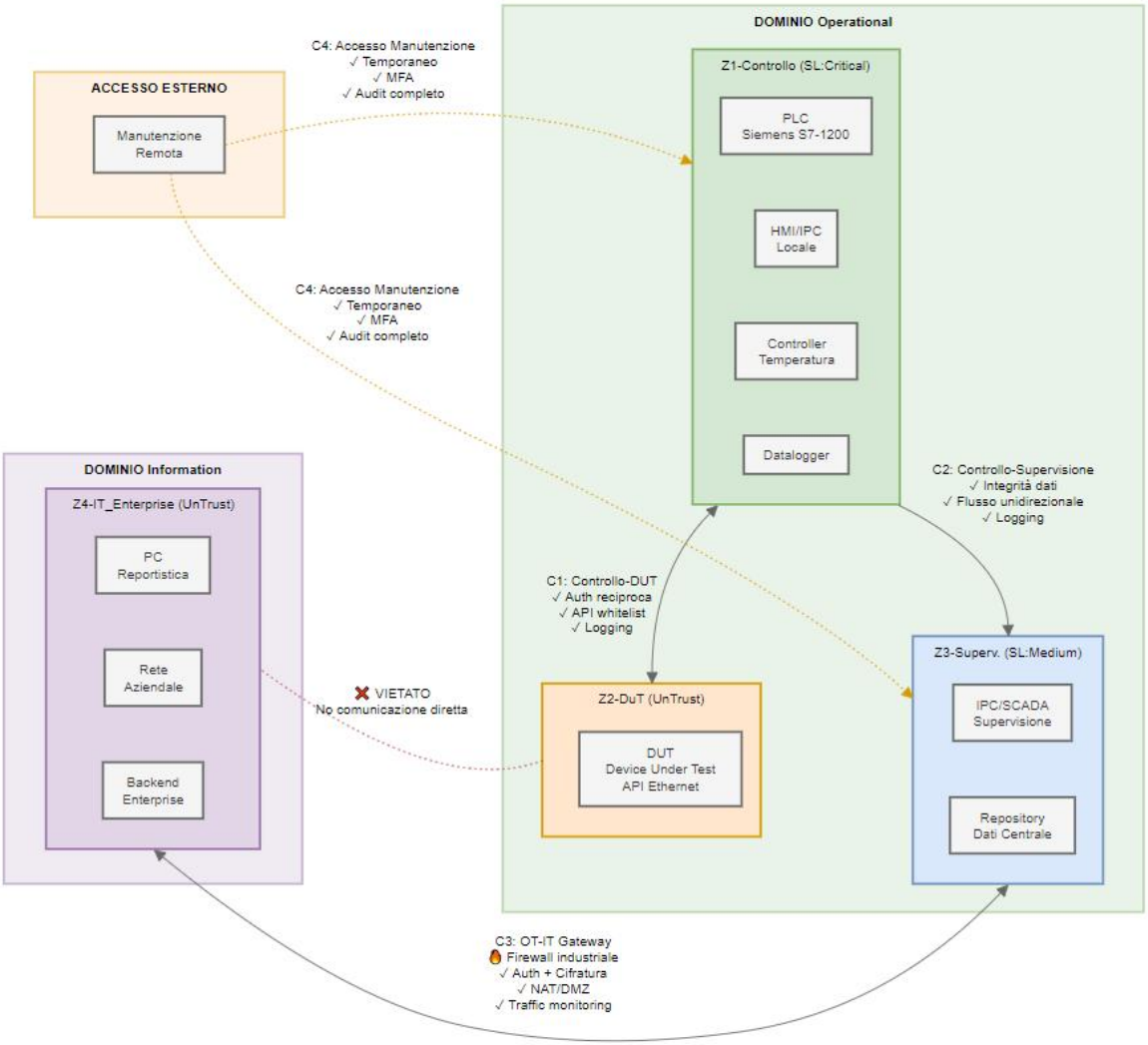
### 3.2.3 Vista d'Insieme: Diagramma Zone & Conduits

Il seguente diagramma fornisce una rappresentazione visuale complessiva del modello di segmentazione Zone & Conduits per il sistema Industrial Test Bench secondo IEC 62443-3-2.

I dettagli implementativi completi di ciascuna zona e conduit, inclusi i controlli di sicurezza specifici e i requisiti SL2 associati, sono approfonditi nella sezione FR5 (§5.5).

```
graph TB
    subgraph DOMINIO_OT["DOMINIO Operational"]
        direction TB

        subgraph Z1["Z1-Controllo (SL:Critical)"]
            PLC["PLC<br/>Siemens S7-1200"]
            HMI["HMI/IPC<br/>Locale"]
            TC["Controller<br/>Temperatura"]
            DL["Datalogger"]
        end

        subgraph Z2["Z2-DuT (UnTrust)"]
            DUT["DUT<br/>Device Under Test<br/>API Ethernet"]
        end

        subgraph Z3["Z3-Superv. (SL:Medium)"]
            SCADA["IPC/SCADA<br/>Supervisione"]
            DB["Repository<br/>Dati Centrale"]
        end
    end
```

```
    subgraph DOMINIO_IT["DOMINIO Information"]
        subgraph Z4["Z4-IT_Enterprise (UnTrust)"]
            PC["PC<br/>Reportistica"]
            NET["Rete<br/>Aziendale"]
            BACKEND["Backend<br/>Enterprise"]
        end
    end

    subgraph EXTERNAL["ACCESSO ESTERNO"]
        MAINT["Manutenzione<br/>Remota"]
    end

    %% Conduits con controlli di sicurezza
    Z1 <-->|"C1: Controllo-DUT<br/>✓ Auth reciproca<br/>✓ API whitelist<br/>✓ Logging"| Z2

    Z1 -->|"C2: Controllo-Supervisione<br/>✓ Integrità dati<br/>✓ Flusso unidirezionale<br/>✓ Logging"| Z3

    Z3 <-->|"C3: OT-IT Gateway<br/>  Firewall industriale<br/>✓ Auth + Cifratura<br/>✓ NAT/DMZ<br/>✓ Traffi
c monitoring"| Z4

    MAINT -.->|"C4: Accesso Manutenzione<br/>✓ Temporaneo<br/>✓ MFA<br/>✓ Audit completo"| Z1

    MAINT -.->|"C4: Accesso Manutenzione<br/>✓ Temporaneo<br/>✓ MFA<br/>✓ Audit completo"| Z3

    %% Evidenziazione NO COMMUNICATION (linea tratteggiata per indicare divieto)
    Z2 -.-|"✕ VIETATO<br/>No comunicazione diretta"| Z4

    %% Styling
    classDef zoneControl fill:#e1f5e1,stroke:#2e7d32,stroke-width:3px,color:#000
    classDef zoneDUT fill:#fff3e0,stroke:#e65100,stroke-width:3px,color:#000
    classDef zoneSupervision fill:#e3f2fd,stroke:#1565c0,stroke-width:3px,color:#000
    classDef zoneIT fill:#f3e5f5,stroke:#6a1b9a,stroke-width:3px,color:#000
    classDef domainOT fill:#f1f8f4,stroke:#1b5e20,stroke-width:2px,stroke-dasharray: 5 5
    classDef domainIT fill:#faf4f9,stroke:#4a148c,stroke-width:2px,stroke-dasharray: 5 5

    class Z1 zoneControl
    class Z2 zoneDUT
    class Z3 zoneSupervision
    class Z4 zoneIT
    class DOMINIO_OT domainOT
    class DOMINIO_IT domainIT
```




Legenda del Diagramma:

- **Domini**: Separazione logica tra Operational Technology (OT) e Information Technology (IT)
- **Zone (Z1-Z4)**: Raggruppamenti di asset con requisiti di sicurezza comuni
    - **Z1 (Controllo)**: Zona critica con PLC, HMI, sensori e attuatori
    - **Z2 (DUT)**: Device Under Test, considerato potenzialmente non trusted
    - **Z3 (Supervisione)**: Sistema di supervisione e storage dati
    - **Z4 (IT Enterprise)**: Rete aziendale e backend
- **Conduits (C1-C4)**: Canali di comunicazione controllati tra zone
    - **Frecce solide** (↔): Comunicazione bidirezionale controllata
    - **Frecce tratteggiate** (··· →): Accesso temporaneo/occasionale
    - **Croce rossa** ( ✗ ): Comunicazione esplicitamente vietata
- **Simboli di controllo**:
    - ✓ Controlli di sicurezza implementati
    - 🔥 Firewall/Gateway di sicurezza
    - ✕ Divieto esplicito di comunicazione

Principi applicati:

1. **Separation of Concerns**: Separazione netta OT/IT e controllo/supervisione
2. **Default Deny**: Comunicazione Z2↔Z4 esplicitamente vietata
3. **Least Privilege**: Ogni conduit implementa solo i flussi strettamente necessari
4. **Defense in Depth**: Controlli multipli su ogni conduit (autenticazione + autorizzazione + logging)

## 8.4. 4. Determinazione del Security Level Target

Basato su:

- Esposizione dell'ambiente industriale
- Probabilità moderata di abuso o manomissione
- Presenza di implicazioni di sicurezza
- Nessun modello di minaccia avanzato nation-state

Il Security Level Target raccomandato è:

### 8.4.1. SL-T = 2

SL2 fornisce protezione contro:

- Violazioni intenzionali utilizzando mezzi semplici
- Attaccanti con risorse limitate
- Malware generico
- Scenari di abuso da parte di insider

## 8.5. 5. IEC 62443-3-3 Foundational Requirement Assessment e Requisiti TO-BE

### 8.5.1. FR1 – Identification & Authentication Control (IAC)

#### Stato AS-IS

- Nessuna autenticazione strutturata su PLC/HMI
- Nessuna identità utente unica
- Autenticazione API DUT non definita

#### Requisiti SL2

- ID utente univoci
- Meccanismi di autenticazione robusti
- Controllo e gestione delle sessioni

#### Valutazione

- SL-A ≈ 0
- Gap Severity: **Alto**

### Implicazioni Architetturali TO-BE

- Implementazione di un sistema di autenticazione su HMI/IPC
- Introduzione di identità per-device per comunicazioni verso backend
- Gestione controllata delle sessioni (timeout, rinnovo, chiusura)
- Autenticazione delle API del DUT con credenziali dedicate
- Meccanismi di strong authentication (es. password policy, multi-factor dove applicabile)

## 8.5.2. FR2 – Use Control (UC)

### Stato AS-IS

- Nessun controllo accessi basato sui ruoli
- Nessuna separazione dei privilegi
- Accesso completo a tutte le funzioni per chiunque

### Requisiti SL2

- Controllo accessi basato sui ruoli (RBAC)
- Principio del minimo privilegio
- Enforcement dei diritti di accesso

### Valutazione

- SL-A ≈ 0
- Gap Severity: Alto

### Implicazioni Architetturali TO-BE

- Definizione di un modello RBAC esplicito con ruoli:
    - Operatore: avvio test, supervisione, lettura dati
    - Manutentore: diagnostica, configurazione parametri non critici
    - Amministratore: gestione sistema, configurazioni di sicurezza
- Enforcement applicativo dei privilegi a livello HMI/IPC
- Separazione tra funzioni operative e funzioni di configurazione
- Logging degli accessi privilegiati

## 8.5.3. FR3 – System Integrity (SI)

### Stato AS-IS

- Nessuna verifica di integrità firmware/software
- Nessuna gestione formale della configurazione
- Nessun processo di aggiornamento controllato
- Configurazioni modificabili senza tracciabilità

### Requisiti SL2

- Protezione contro modifiche non autorizzate
- Meccanismi di garanzia dell'integrità
- Procedure di aggiornamento controllate e verificabili

### Valutazione

- SL-A ≈ 0
- Gap Severity: **Alto**

### Implicazioni Architetturali TO-BE

- Introduzione di **Root of Trust** a livello hardware/firmware
- Implementazione di **Secure Boot** con verifica crittografica delle immagini
- Meccanismo di aggiornamento firmware autenticato e firmato digitalmente
- Protezione dell'integrità delle configurazioni critiche (checksum, firma)
- Versioning formale delle configurazioni
- Meccanismi di rollback controllato in caso di corruzione
- Protezione anti-tampering per parametri di sicurezza

## 8.5.4. FR4 – Data Confidentiality (DC)

### Stato AS-IS

- Dati memorizzati in CSV in chiaro
- Nessuna crittografia dei dati sensibili
- Media rimovibili (USB/SD) non controllati
- Nessuna classificazione dei dati

### Requisiti SL2

- Protezione dei dati sensibili in transito e a riposo
- Crittografia dove necessario
- Controllo dell'accesso ai dati

### Valutazione

- SL-A ≈ 0
- Gap Severity: **Medio**

### Implicazioni Architetturali TO-BE

- **Classificazione dei dati** per livello di sensibilità:
    - Dati di processo pubblici (temperature, pressioni aggregate)
    - Dati sensibili (ricette, configurazioni, credenziali)
- Cifratura dei dati sensibili in transito (TLS/DTLS per comunicazioni di rete)
- Cifratura opzionale dei dati a riposo per configurazioni critiche
- Politica di gestione e controllo dei supporti rimovibili:
    - Logging degli accessi
    - Disabilitazione selettiva ove non necessario
- Protezione delle credenziali (no plaintext storage)

### 8.5.5. FR5 – Restricted Data Flow (RDF)

#### Stato AS-IS

- Nessuna segmentazione di rete formale
- Nessun firewall o controllo dei condotti
- Accesso Ethernet diretto al DUT senza controlli
- Condotti fisici non controllati (USB/SD)

#### Requisiti SL2

- Zone e Conduits formalmente definiti
- Controllo dei flussi tra zone
- Segmentazione logica della rete

#### Valutazione

- SL-A ≈ 0
- Gap Severity: Alto

#### Implicazioni Architetturali TO-BE

##### Principi di Segmentazione

Il modello Zone & Conduits è costruito secondo i seguenti principi:

- Separazione tra dominio OT e dominio IT
- Separazione tra funzioni di controllo e funzioni di supervisione
- Isolamento del DUT (Device Under Test) come entità distinta
- Controllo esplicito di ogni flusso dati tra domini
- Assunzione che ogni zona sia non trusted rispetto alle altre

La segmentazione è sia logica (VLAN, firewall, ACL) che fisica dove necessario.

##### Definizione delle Zone

Zona Z1 – Controllo

Comprende:

- PLC (Siemens S7-1200)
- IPC / HMI locale
- Controllore di temperatura
- Datalogger

Caratteristiche:

- Funzione critica per l'operatività del sistema
- Elevato impatto in caso di compromissione
- Accesso limitato a personale autorizzato

Requisiti SL2 associati: FR1 (autenticazione utenti), FR2 (RBAC), FR3 (integrità software e configurazioni), FR6 (logging eventi critici)

Zona Z2 – DUT (Device Under Test)

Comprende:

- Dispositivo oggetto di test
- API di comunicazione verso il sistema di controllo

Caratteristiche:

- Entità potenzialmente non trusted
- Superficie di attacco diretta tramite Ethernet

Requisiti SL2 associati: FR1 (autenticazione API), FR3 (integrità comunicazioni), FR5 (controllo flussi verso Z1)

> **Nota architetturale**: Il DUT non deve poter influenzare direttamente la zona di controllo senza attraversare un conduit controllato.

Zona Z3 – Supervisione / Storage

Comprende:

- Storage locale / repository dati
- IPC/SCADA per supervisione
- Eventuale server di supervisione futuro

Caratteristiche:

- Contiene dati di test aggregati
- Può interfacciarsi con IT aziendale

Requisiti SL2 associati: FR4 (protezione dati), FR6 (event logging e forwarding), FR5 (segmentazione verso IT)

Zona Z4 – IT Enterprise

Comprende:

- Rete aziendale
- PC per reportistica
- Backend enterprise
- Sistemi remoti di manutenzione

Caratteristiche:

- Considerata non trusted rispetto al dominio OT
- Accesso remoto controllato tramite gateway

Requisiti SL2 associati: FR5 (restricted data flow), FR1 (autenticazione device-server)

### Definizione dei Conduits

Ogni comunicazione tra zone avviene esclusivamente tramite conduits definiti e controllati.

Conduit C1 – Z1 ↔ Z2 (Controllo-DUT)

- Protocollo controllato e autenticato
- Autenticazione reciproca device-to-device
- Limitazione delle funzioni API esposte (whitelist)
- Logging completo delle interazioni

Obiettivo: Impedire che un DUT compromesso possa compromettere la zona di controllo.

Conduit C2 – Z1 ↔ Z3 (Controllo-Supervisione)

- Trasferimento controllato dei dati di test
- Controllo di integrità dei dati (checksum, firma)
- Logging delle operazioni di trasferimento
- Flusso unidirezionale preferito (Z1 → Z3)

Conduit C3 – Z3 ↔ Z4 (Supervisione-IT)

- Firewall industriale o gateway dedicato
- Accesso remoto autenticato e cifrato
- Segmentazione rigida IT/OT

- Monitoraggio del traffico e detection anomalie
- NAT per mascheramento indirizzi OT

Conduit C4 – Accesso Manutenzione (esterno → Z1/Z3)

- Accesso temporaneo e limitato nel tempo
- Autenticazione forte (multi-factor dove possibile)
- Tracciabilità completa delle operazioni
- Canale dedicato isolato dal traffico operativo

#### Regole Generali sui Flussi

- **Nessuna comunicazione diretta** tra Z2 (DUT) e Z4 (IT)
- **Nessuna comunicazione non autenticata** tra zone
- Ogni flusso deve essere **esplicitamente giustificato** e documentato
- Le porte e servizi non utilizzati devono essere **disabilitati**
- **Default deny**: tutto ciò che non è esplicitamente permesso è vietato
- **Monitoraggio continuo** del traffico sui conduits per rilevare anomalie

#### Collegamento con le Foundational Requirements

Il modello Zone & Conduits rappresenta la misura architettonica primaria per:

- **FR5 (Restricted Data Flow)**: segmentazione e controllo dei flussi
- **FR1 (Authentication)**: autenticazione device-to-device sui conduits
- **FR2 (Use Control)**: enforcement dei privilegi per zona
- **FR6 (Event Logging)**: tracciabilità dei flussi tra zone
- **FR7 (Availability)**: limitazione propagazione di attacchi DoS

La segmentazione riduce la superficie d'attacco e limita la propagazione laterale in caso di compromissione.

### 8.5.6. FR6 – Timely Response to Events (TRE)

#### Stato AS-IS

- Nessun logging degli eventi di sicurezza
- Nessun sistema di monitoraggio
- Nessun processo di risposta agli incidenti
- Eventi non tracciati né correlabili

#### Requisiti SL2

- Event logging degli eventi di sicurezza rilevanti
- Capacità di rilevazione e allerta
- Procedura di risposta definita

#### Valutazione

- SL-A ≈ 0
- Gap Severity: **Alto**

#### Implicazioni Architetturali TO-BE

- Implementazione di **logging locale** degli eventi critici:

    - Tentativi di autenticazione (successi e fallimenti)
    - Modifiche configurazione
    - Comandi critici inviati
    - Allarmi di sicurezza
    - Accessi ai dati sensibili
- Timestamping affidabile degli eventi (sincronizzazione tempo)
- Meccanismo di **forwarding sicuro** dei log verso sistema di supervisione/SIEM
- Protezione dell'integrità dei log (append-only, firma)
- Capacità di alerting per eventi critici (locale e remoto)
- Architettura predisposta per integrazione con processi di **incident response**
- Retention policy dei log coerente con requisiti normativi

### 8.5.7. FR7 – Resource Availability (RA)

#### Stato AS-IS

- Nessuna valutazione di resilienza
- Nessuna protezione dall'esaurimento delle risorse
- Nessun meccanismo watchdog formalmente definito
- Vulnerabilità potenziale a DoS non valutata

#### Requisiti SL2

- Resilienza di base a scenari denial-of-service
- Meccanismi di protezione della disponibilità
- Recovery da condizioni anomale

#### Valutazione

- SL-A ≈ 0-1 (alcuni dispositivi hanno watchdog hardware base)
- Gap Severity: **Medio**

#### Implicazioni Architetturali TO-BE

- Introduzione di **watchdog hardware e software** su componenti critici
- Meccanismi di **timeout** su tutte le comunicazioni di rete
- **Rate limiting** su interfacce esposte (API, servizi di rete)
- Gestione controllata delle **connessioni concorrenti** (max connection limit)
- Monitoraggio delle risorse critiche (CPU, memoria, storage)
- Meccanismi di **graceful degradation** (degradazione controllata in caso di sovraccarico)
- Separazione tra traffico operativo e traffico di gestione
- Testing di resilienza a condizioni di stress/flood

## 8.6. 6. Sicurezza a Livello di Componente (IEC 62443-4-2)

PLC: - Nessuna baseline di hardening documentata - Esposizione dei servizi di default non valutata

HMI: - Nessuna policy di hardening OS - Nessuna governance delle patch

DUT: - Autenticazione API non valutata - Baseline di configurazione sicura non definita

SL-C dei componenti non formalmente determinato.

Gap: Ciclo di vita della sicurezza dei componenti assente.

## 8.7. 7. Valutazione del Programma di Sicurezza (IEC 62443-2-1)

AS-IS: - Nessuna policy di cybersecurity documentata - Nessun inventario degli asset - Nessuna gestione delle vulnerabilità - Nessuna gestione delle patch - Nessun piano di risposta agli incidenti - Nessun ruolo di cybersecurity definito

SL2 richiede: - Sistema formale di gestione della sicurezza - Responsabilità definite - Revisione periodica - Formazione - Integrazione della gestione delle modifiche

Gap: Programma di sicurezza organizzativo non implementato.

## 8.8. 8. Valutazione Complessiva del Security Level

| Foundational Requirement | SL-A (Actual) | SL-T (Target) | Gap Severity |
|---|---|---|---|
| FR1 – IAC | 0 | 2 | High |
| FR2 – UC | 0 | 2 | High |
| FR3 – SI | 0 | 2 | High |
| FR4 – DC | 0 | 2 | Medium |
| FR5 – RDF | 0 | 2 | High |
| FR6 – TRE | 0 | 2 | High |
| FR7 – RA | 0–1 | 2 | Medium |
| Livelo Complessivo | 0–1 | 2 | Medium–High |

Leggenda

- FR1 – Identification and Authentication Control (IAC)
- FR2 – Use Control (UC)
- FR3 – System Integrity (SI)
- FR4 – Data Confidentiality (DC)
- FR5 – Restricted Data Flow (RDF)
- FR6 – Timely Response to Events (TRE)
- FR7 – Resource Availability (RA)

## 8.9. 9. Conclusione Esecutiva e Roadmap AS-IS → TO-BE

### 8.9.1. 9.1 Sintesi della Gap Analysis

La configurazione attuale del test bench industriale:

- È fisicamente sicura ma cyber-immatura: SL-A complessivo ≈ 0-1

- **Manca di zone e condotti definiti**: nessuna segmentazione formale
- **Non ha un modello di autenticazione o controllo accessi**: accesso non controllato
- **Manca di meccanismi di protezione dell'integrità**: no secure boot, no verifica firmware
- **Non ha monitoraggio degli eventi di sicurezza**: visibilità cyber assente
- **Non ha un programma formale di governance della cybersecurity**: processo ad-hoc

## 8.9.2. 9.2 Requisiti Architetturali per SL2

Per raggiungere la conformità **SL-T = 2** secondo IEC 62443, l'architettura TO-BE deve implementare quanto segue.

### Requisiti di Sistema (IEC 62443-3-3)

- Segmentazione formale di zone e condotti con controllo dei flussi
- Sistema di identificazione e autenticazione degli utenti e dei dispositivi
- Modello RBAC con separazione dei privilegi
- Controlli di integrità del sistema (Secure Boot, firmware autenticato)
- Classificazione e protezione dei dati sensibili
- Event logging e capacità di detection/response
- Meccanismi di resilienza e protezione della disponibilità

### Requisiti di Componente (IEC 62443-4-2)

- Hardening baseline per PLC, HMI, IPC
- Gestione sicura del ciclo di vita dei componenti
- Patch management strutturato

### Requisiti Organizzativi (IEC 62443-2-1)

- Policy di cybersecurity documentata
- Inventario degli asset e classificazione
- Gestione delle vulnerabilità e delle patch
- Piano di risposta agli incidenti
- Ruoli e responsabilità definiti
- Programma di formazione

## 8.9.3. 9.3 Tracciabilità dei Requisiti

Tutti i requisiti architetturali identificati in questo documento devono essere tracciabili verso:

- **Upstream**: Foundational Requirements IEC 62443-3-3 e GAP identificati
- **Downstream**: Decisioni progettuali nel documento "Cybersecurity Architecture Definition"

La matrice di tracciabilità deve garantire che ogni gap critico (severity: High) sia indirizzato da almeno una misura architettonica nel TO-BE.

## 8.9.4. 9.4 Principi Guida per il TO-BE

1. **Defense in Depth**: implementare controlli multipli e complementari
2. **Least Privilege**: limitare accessi e privilegi al minimo necessario
3. **Separation of Concerns**: separare controllo processo, sicurezza funzionale e cybersecurity
4. **Secure by Design**: integrare la sicurezza fin dalla fase di progettazione

5. **Resilience**: garantire continuità operativa anche in presenza di eventi cyber

**Questa analisi GAP costituisce la Requirement Baseline formale per la migrazione strutturata verso la conformità IEC 62443 SL2.**

Il documento successivo "Cybersecurity Architecture Definition – Risk-Informed Baseline for Embedded Industrial Systems" tradurrà questi requisiti in decisioni architetturali concrete.